



République du Cameroun

Paix-Travail-Patrie

Ministère de l'Enseignement
Supérieur

Université de Garoua

Faculté des Sciences

Division des Affaires
Académiques, de la Scolarité et
de la Recherche

Republic of Cameroon

Peace-Work-Fatherland

Ministry of Higher Education

Université de Garoua

Faculté of Science

Division of Academic Affairs,
Student's Admission and



UE : Supervision, Analyse Forensique et Gestion des incidents

N°	Noms et prénoms	Matricule	NIVEAU
1	KLAVAC TOUNIDE	CM-UGa-24FS0785	MASTER II

Année Académique : 2025-2026

CHAPITRE 7 :

EXERCICE

Exercice 7.1 : Analyse mémoire (Forensique RAM)

L'analyse de la mémoire vive (RAM) est une discipline essentielle du forensique numérique. Elle permet d'obtenir des artefacts volatils non présents sur le disque dur, comme les processus actifs, les connexions réseau en cours, les clés de chiffrement ou les injections de code malveillant. L'outil Volatility 3 est le standard de référence pour cette analyse.

1. Liste des processus suspects

Commande : `python3 vol.py -f memory.dmp windows.pslist`

On recherche les processus anormaux selon plusieurs critères :

- Noms inhabituels ou usurpant un processus légitime (svchost.exe sans parent services.exe, lsass.exe dupliqué)
- Présence d'interpréteurs comme nc.exe (netcat), cmd.exe ou powershell.exe lancés par un processus web
- Arguments en Base64 : powershell.exe -EncodedCommand <base64_payload> est un marqueur fort d'obfuscation
- PID orphelin : processus sans parent légitime = potentiel malware injecté

2. Connexion réseau active

Commande : `python3 vol.py -f memory.dmp windows.netscan`

On identifie une connexion ESTABLISHED depuis l'IP locale (10.0.0.5) vers 203.0.113.42:4444, confirmant un Reverse Shell actif. Le port 4444 est le port par défaut de Metasploit. La connexion active confirme que l'attaquant maintient un accès persistant au système au moment de l'acquisition.

3. Détection d'injections de code (Malfind)

Commande : `python3 vol.py -f memory.dmp windows.malfind`

Ce plugin identifie les régions mémoire avec des permissions anormales (PAGE_EXECUTE_READWRITE = RWX). Ces zones sont suspectes car les exécutables légitimes n'ont généralement pas de sections à la fois écrivables ET exécutables. On y trouve :

- Du shellcode injecté (séquences MZ/PE en début de région)

- Des DLL chargées de manière réflexive (Reflective DLL Injection)
- Des payloads Cobalt Strike ou Meterpreter résidant en mémoire uniquement (fileless malware)

4. Détection des processus cachés (DKOM)

Approche comparative entre deux plugins :

Plugin	Principe	Ce qu'il trouve
windows.pslist	Parcourt la liste chaînée PsActiveProcessHead dans le noyau	Processus visibles par l'OS
windows.psscan	Scanne toutes les structures EPROCESS en mémoire	Tous les processus, y compris cachés

Interprétation : Si un PID apparaît dans psscan mais est absent de pslist, il a été retiré de la liste chaînée par un rootkit via la technique DKOM (Direct Kernel Object Manipulation). C'est la signature typique d'un rootkit noyau de niveau 0.

Exercice 7.2: Analyse réseau

L'analyse du trafic capturé (PCAP) permet de reconstituer la kill chain de l'attaquant et d'identifier le volume et la nature des données exfiltrées.

1. Identification du serveur C2

IP de Commande & Contrôle identifiée : 203.0.113.42 (appartenant à un bloc TEST-NET-3, généralement rouge en prod). Le trafic présente des communications périodiques (beacons) avec un intervalle régulier, caractéristique d'un RAT (Remote Access Trojan) ou d'un agent Cobalt Strike avec jitter bas.

2. Protocole de communication

- HTTPS (port 443) : Le plus fréquent pour contourner les pare-feux en se fondant dans le trafic légitime. Utiliser Zeek + JA3 pour fingerprinter le client TLS même sans déchiffrement.
- DNS Tunneling : Volume anormal de requêtes TXT ou NULL vers un domaine contrôlé par l'attaquant. Outil de détection : dnstop ou Zeek dns.log avec analyse d'entropie.

- ICMP Tunneling : Données cachées dans le champ Data des paquets ICMP Echo.

3. Identification du serveur C2

Dans Wireshark, à partir du flux TCP (Follow TCP Stream), on identifie une requête POST volumineuse contenant le fichier Donnees_Client.zip. Les indicateurs clés sont :

- Content-Length élevé dans les headers HTTP POST
- Entropy élevée du payload (données compressées/chiffrées)
- Destination vers une IP sans PTR record ou un domaine enregistré récemment

4. Identification du serveur C2

Via Zeek conn.log, la durée est calculée par la différence ts_end - ts_start entre le premier et le dernier paquet. Résultat : 2 heures 14 minutes d'activité C2 continue, ce qui indique une exfiltration méthodique plutôt qu'une attaque opportuniste.

Exercice 7.3: Analyse CloudTrail(AWS)

L'événement CreateAccessKey depuis une IP TOR est classé IoC Critique car il combine trois signaux : accès depuis réseau d'anonymisation, création d'une clé de persistance, et heure de nuit (03:22 UTC).

Actions d'investigation prioritaires

- Identification de l'identité compromise : Extraire le champ userIdentity.arn du log pour déterminer quel compte IAM ou rôle a servi de vecteur. Vérifier si ce compte a des droits excessifs (principe du moindre privilège).
- Audit des actions post-crétion : Requête CloudTrail filtrée sur la nouvelle accessKeyId pour identifier l'ensemble des actions menées après 03:22 UTC.
- Recherche d'élévation de privilèges : Filtrer les événements AttachUserPolicy, PutUserPolicy, CreateRole pour détecter une élévation de droits IAM.
- Recherche d'exfiltration S3 : Vérifier les appels ListBuckets, GetObject, PutBucketPolicy sur les buckets sensibles de LiZbiZ.

Sources de logs à corréler

Source	Données disponibles	Priorité
AWS CloudTrail	Historique complet des appels API (qui, quoi, quand, depuis où)	P0
Amazon GuardDuty	Alertes automatiques : UnauthorizedAccess:IAMUser/TorIPCaller	P0
VPC Flow Logs	Flux réseau entrant/sortant des instances EC2 associées	P1
S3 Server Access Logs	Accès aux objets S3 (GetObject, DeleteObject)	P1

CHAPITRES VIII :

EXERCICE

Exercice 8.1 : Playbook de Réponse aux Incidents (Ransomware)

Un playbook est un ensemble de procédures structurées permettant une réponse homogène, rapide et traçable face à un incident de sécurité. Voici le playbook complet pour un incident de type Ransomware :

Étape	Actions / Décisions	Outils	Responsable / Escalade
Détection	Alerte EDR/SIEM. Vérifier si le processus chiffant est légitime. Corréler avec logs réseau.	Wazuh, Sysmon, EDR	N1 → N2 si confirmé
Isolation	Couper le réseau de la/des machine(s) infectée(s). Isoler le segment VLAN concerné au niveau switch.	Switch (VLAN quarantaine)	Responsable Infra
Analyse	Identifier la souche ransomware (ID Ransomware), le vecteur d'entrée (RDP, phishing, vuln).	VirusTotal, Volatility, Wireshark	Expert Forensique
Éradication	Supprimer le malware et ses mécanismes de persistance. Réinitialiser les mots de passe compromis.	EDR, BASH, Regedit	DSI
Récupération	Restaurer les données depuis les sauvegardes validées (non chiffrées). Vérifier l'intégrité des backups avant restauration.	Cloud Backup, Veeam	DG + DSI
Post-Mortem	Rédiger le rapport RETEX. Mettre à jour les règles IDS/IPS. Former les équipes.	Rapport d'incident, MITRE	Tous les membres

Exercice 8.2 : Classification de l'alerte : Modification de /etc/passwd

CRITIQUE	Incident Majeur - Elevation de privilèges confirmée (Privilege Escalation + RCE)
-----------------	--

Justification technique détaillée :

- L'utilisateur www-data est le compte sous lequel s'exécute Apache/Nginx. Il ne doit jamais avoir accès en écriture au fichier /etc/passwd.
- Cette modification indique une exploitation réussie d'une faille RCE (Remote Code Execution) dans l'application web, permettant à l'attaquant d'exécuter des commandes système.
- L'ajout d'une entrée dans /etc/passwd signifie un accès persistant avec un compte local créé par l'attaquant.
- Technique MITRE ATT&CK associée : T1136.001 (Create Account: Local Account) + T1078 (Valid Accounts).

5 premières actions immédiates (ordonnées par urgence)

- [P0 - Immédiat] Isolation Réseau : Couper srv-web-01 du réseau pour stopper tout mouvement latéral vers l'ERP ou d'autres serveurs. Appliquer une règle de quarantaine au niveau switch/pare-feu.
- [P0 - 0-15 min] Capture de la RAM : Acquérir la mémoire volatile AVANT tout redémarrage. Commande : sudo avml /tmp/memory.dmp. Cela préserve le reverse shell actif, les clés en mémoire et l'exploit utilisé.
- [P1 - 15-30 min] Audit des processus : ps aux | grep www-data. Identifier tout processus fils lancé par www-data (bash, nc, python reverse shells).
- [P1 - 30-60 min] Vérification de l'intégrité : Comparer /etc/passwd avec une version de référence (depuis backup ou outil AIDE). Identifier le(s) compte(s) ajouté(s) par l'attaquant.
- [P2 - 1-2h] Revue des logs WAF/Apache : grep -E '(200|500)' /var/log/apache2/access.log | grep '\.php'. Identifier l'URL ayant permis l'injection de commande (webshell, upload non filtré).

Exercice 8.3 : Rapport d'incident à la Direction générale

Destinataire	Monsieur le Directeur Général de LiZbiZ
Objet	Rapport de situation — Intrusion du 07 Juin 2026
Classification	CONFIDENTIEL — DIFFUSION RESTREINTE

1. Nature de l'incident

Le 07 juin 2026, entre 02h47 et 04h00, l'infrastructure de LiZbiZ a subi une cyberattaque ciblée. Un acteur malveillant a pénétré le système d'information en exploitant une vulnérabilité RCE sur le serveur web public, puis a effectué un mouvement latéral vers le serveur ERP contenant les données clients. L'attaque a abouti à l'exfiltration de 100 dossiers clients.

2. Chronologie de l'incident

Heure	Événement	Technique MITRE
02:47	Détection d'un scan de ports sur le périmètre	T1595 (Recon)
03:14	Accès SSH non autorisé sur srv-web-01 (brute force réussi)	T1110 (Brute Force)
03:21	Mouvement latéral via SMB vers le serveur ERP	T1021.002 (SMB)
03:22	Création d'une clé d'accès AWS depuis IP TOR	T1078 (Valid Accounts)
03:48	Effacement des journaux système (anti-forensique)	T1070.001 (Clear Logs)
04:00	Détection par l'équipe SOC et déclenchement du plan de réponse	—

3. Impact constaté

- Données : Environ 50 000 dossiers clients (noms, adresses, contrats) exfiltrés. Tentative d'effacement des traces sur le serveur comptable.
- Opérationnel : Services de facturation suspendus 4 heures. Interruption partielle du service client.

- Réglementaire : Obligation de notification à l'ANTIC sous 72h (Loi camerounaise 2010/012). Non-respect passible de sanctions.

4. Coûts estimés

- Expertise technique et remise en état : ~5 000 000 FCFA
- Pertes opérationnelles (4h d'arrêt facturation) : à évaluer
- Risque de sanctions ANTIC et préjudice réputationnel : non quantifié

5. Mesures immédiates prises

- Isolation des serveurs touchés pour stopper la progression de l'attaquant.
- Colmatage de la faille RCE exploitée sur le serveur web.
- Suppression des comptes et clés d'accès créés par l'attaquant.
- Lancement d'une enquête numérique approfondie (forensique mémoire + disque + réseau).

6. Recommandations stratégiques

- [P0] Mise en place d'une segmentation réseau VLAN entre le serveur Web et l'ERP (zero-trust interne).
- [P0] Activation de l'authentification multi-facteurs (MFA) sur tous les accès SSH, RDP et AWS.
- [P1] Déploiement de Fail2Ban avec blocage après 3 échecs de connexion SSH.
- [P1] Centralisation des logs en temps réel sur un SIEM distant en lecture seule (immutabilité).
- [P2] Sensibilisation anti-phishing trimestrielle pour l'ensemble du personnel.
- [P2] Test d'intrusion annuel par un prestataire certifié.